

SecCore Essentials - Active Directory Tier Model



seccore.at/blog/ad-tiering

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This blog posts highlights important configurations and design implementations of an Active Directory Tiering model. This SecCore Essential is considered implemented if the following conditions are met:

- The Active Directory structure consists of at least three tiers for computers, users and service accounts:
 - Tier 0: Domain Layer
 - Tier 1: Enterprise Server Layer
 - Tier 2: Client Workstation Layer
- GPOs that explicitly disallow all forms of logins for users from other tiers are implemented:
 - **Deny log on as a service**
 - **Deny log on as a batch job**
 - **Deny log on locally**
 - **Deny log on through Terminal Services**
- All non-privileged accounts are disallowed from having administrative rights on tiered systems
- Administrators have separate accounts for each tier
- Privileged Access Workstations (PAW) exist for each tier

Introduction

The Microsoft Active Directory access model is not secure by default. Users can be added to any groups and assigned administrative rights on any system, which leads to violations of the **principle of least privileges**¹. Furthermore, without [strong protections on client systems](#), passwords or password-hashes of logged-on users can easily be dumped by an attacker and used for lateral movement.

In order to tackle this problem, the administrative layer of an Active Directory network should be split up into three tiers:

Tier 0 - The Domain Layer

It includes core domain services such as the Domain Controller, Active Directory Federation Services (ADFS) or Active Directory Certificate Services (ADCS). Users in this tier can administer the domain and all its services, which makes it the most privileged layer.

Tier 1 - The Enterprise Server Layer

This layer contains servers that provide enterprise functions, such as databases, file sharing and business applications like ERP. Administrators in this tier can manage servers that are not part of the core Active Directory structure, but still hold sensitive data. Administrative access in this layer should be granted by the principle of least privilege, where specific application administrators only get access to their respective servers.

Tier 2 - The Client Workstation Layer

This layer should only contain client devices. It is the least privileged layer, where administrators only get access to client workstations to troubleshoot problems and help users. This is also the most likely layer through which attackers infiltrate the network.

If implemented correctly, moving from one tier to another should not be possible, neither by administrators nor by attackers.

This also has to be ensured with GPOs so that logins from other tiers are denied.

Additional Information

Systems that manage or back up tier 0 devices or VMs should not be managed within the Active Directory itself. They should not be connected to the domain at all and should therefore not be added to either tiering layer.

Those systems include:

- Virtualization hosts
- Backup systems
- Server management interfaces such as HPE iLO or Dell iDRAC

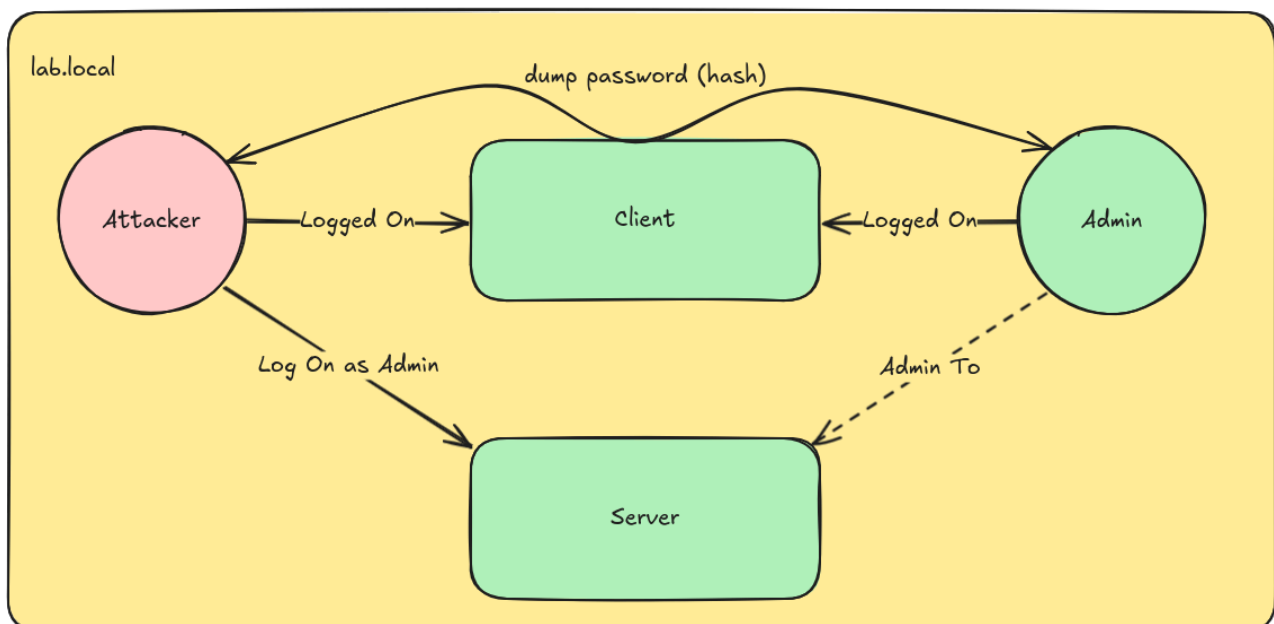
Please refer to [Network Layer Security](#) or [Backup Management](#) for more information about how to protect these systems.

Common Attack Vectors

The following section describes the potential attack vectors that could arise if a tiering model is not implemented correctly or is missing entirely.

Lateral Movement To More Sensitive Systems

Attackers usually try to elevate privileges in their target network or system. In the case of an Active Directory environment, an account in the Domain Administrators group is a common target, due to their extensive privileges. Attacks usually originate from lower-privileged systems, like client workstations. Attackers then try to obtain credentials or access to more sensitive systems, such as database servers or domain controllers. A common attack vector in this case is to read credentials of high privileged users logged on to a low privileged system. If for example a user that has administrative rights on many servers is logged on to a client workstation, their credentials may be compromised if the client workstation is infected by malware.



This attack can be repeated on other systems, until full domain administrator privileges are obtained.

Attack Scenario

This section should demonstrate how attackers may exploit missing AD tiering, to fully compromise the Active Directory. The setup of this attack scenario is as follows:

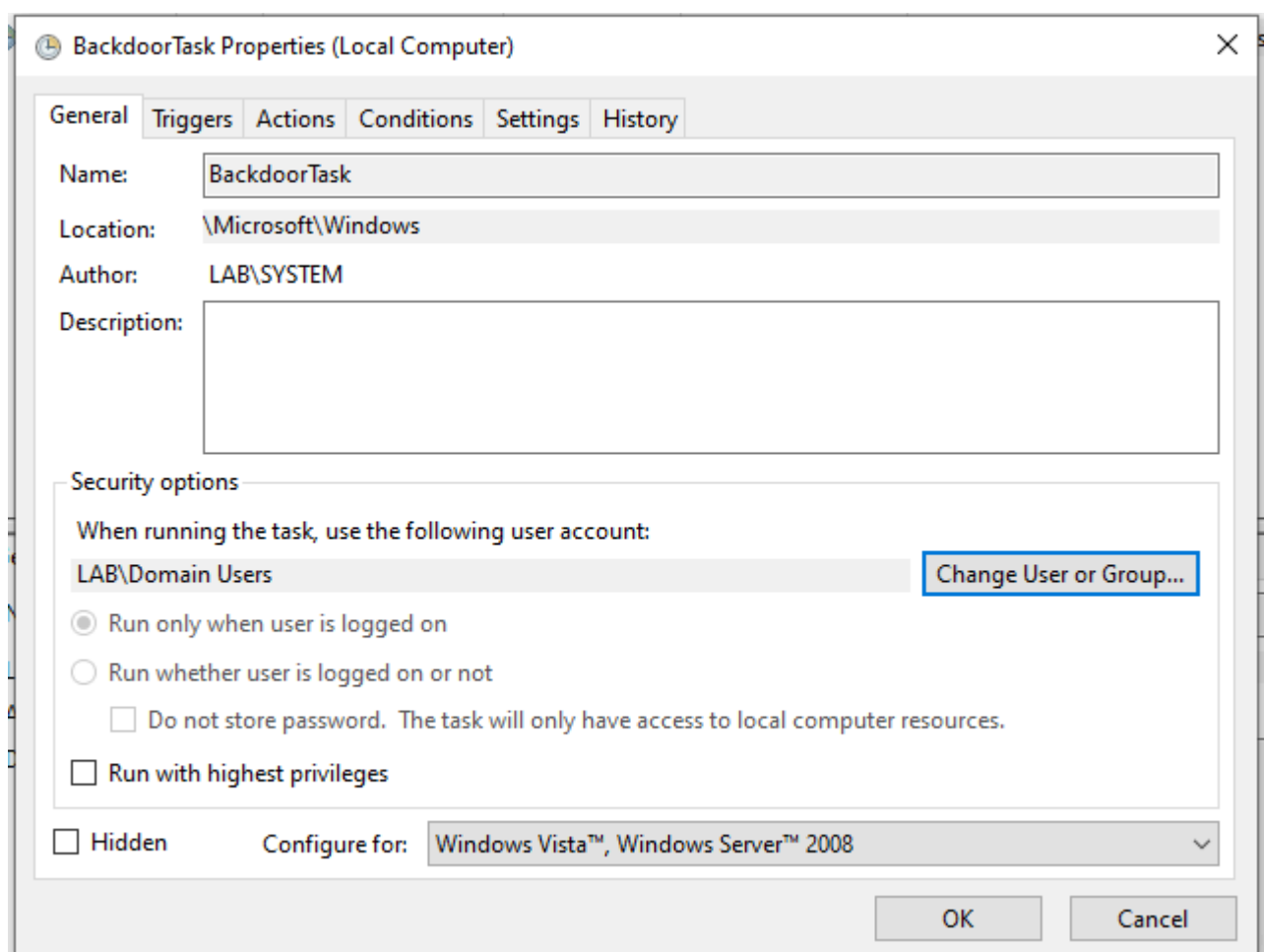
- No AD tiering is implemented
- Domain Admins are used for daily administrative tasks
- The attacker already compromised a client system and has administrative access on it
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

Since the attacker already has administrative access on the compromised client system, they can install a scheduled task as NT AUTHORITY\SYSTEM, which holds the highest privileges on a local Microsoft Windows system.



```
Administrator: C:\Windows\system32\cmd.exe
C:\Windows\system32>whoami
nt authority\system
C:\Windows\system32>taskschd.msc
C:\Windows\system32>
```

With the task scheduler opened, they can create a new task:



As it can be seen in the screenshot above, the task is configured to run under the Domain Users@lab.local group. This is needed, since the task is also configured to run on any user login:

Edit Trigger

Begin the task: At log on

Settings

☒ Any user

☐ Specific user: LAB\Administrator Change User...

Advanced settings

☐ Delay task for: 15 minutes

☐ Repeat task every: 1 hour for a duration of: 1 day

☐ Stop all running tasks at end of repetition duration

☐ Stop task if it runs longer than: 3 days

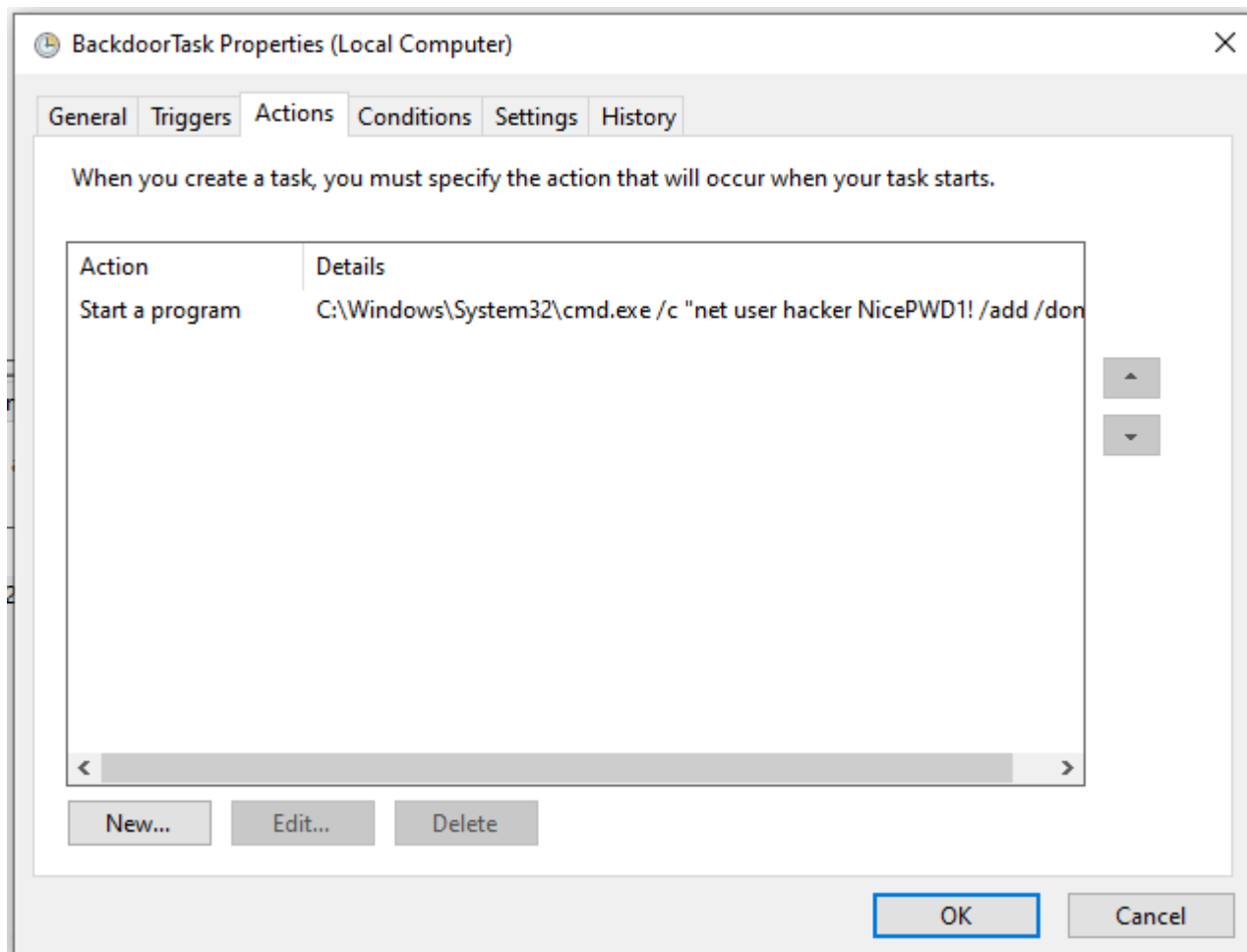
☐ Activate: 21/08/2025 15:31:19 ☐ Synchronize across time zones

☐ Expire: 21/08/2026 15:31:19 ☐ Synchronize across time zones

☒ Enabled

OK Cancel

This essentially means, that whenever a user who is a member of the Domain Users@lab.local group logs in, the scheduled task will run with the privileges of this account. This can be exploited by also registering an action within the task:



This command creates a new AD account and adds it to the Domain Admins@lab.local group:

```
C:\Windows\System32\cmd.exe /c "net user hacker NicePWD1! /add /dom & net group "Domain Admins" /add hacker /dom"
```

Now the attacker only needs to wait for a domain admin to log in to the compromised client system. They can also break something on purpose, so that a support member connects to the system and triggers the scheduled task. This will add the new user hacker@lab.local to the Domain Admins@lab.local group:

```
Administrator: Windows PowerShell
PS C:\Users\Administrator> net group "domain admins"
Group name      Domain Admins
Comment        Designated administrators of the domain
Members
-----
Administrator   hacker
The command completed successfully.
PS C:\Users\Administrator>
```

Mitigation

By implementing the recommended tiering structure and explicitly denying various logon possibilities for Tier 0 and Tier 1 admins on client systems, an attacker is not able to compromise these higher-tier accounts:



LAB\Administrator

The sign-in method you're trying to use isn't allowed. For more info, contact your network administrator.

OK